

OLYMPUS · SECURITY REVIEW

Olympus LZ Integration.

A security review of LZ Integration.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Olympus	LZ Integration	Guardian	April 16 – June 2, 2026	June 9, 2026

§ 00

Contents.

30 pages — overview, confidence ranking, scope, 20 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 16 findings	P. 09
	Remediation Review · 4 findings	P. 25
§ 05	Disclaimer	P. 29
§ 06	About Guardian	P. 30

§ 01

Overview.

Guardian reviewed LZ Integration across 2 review rounds. The final report includes 1 Medium, 3 Low, 16 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	OlympusDA0/olympus-v3
CLIENT	METHODOLOGY
Olympus	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
LZ Integration	aaae73e62330
PREPARED BY	REMEDATION REVIEW COMMIT
Guardian	3068400436ab
AUDIT WINDOW	
April 16 – June 2, 2026	
FINAL REPORT	
June 9, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	1	0	0	0	1
Low	3	0	0	0	3
Informational	16	0	4	0	12
All severities	20	0	4	0	16

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed LZ Integration in `0lympusDA0/olympus-v3`. The scope includes 997 source lines across 5 files.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW
Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
src/periphery/bridge/LZCrossChainBridge.sol	60	106
src/policies/bridge/LZBridgeGateway.sol	297	568
src/libraries/LZConfigLib.sol	161	280
src/proposals/LZBridgeSecurityUpgradeProposal.sol	329	448
src/proposals/LZBridgeActivator.sol	150	235

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
M-01	Optional DVNs inherit LayerZero defaults	Logical Error	MEDIUM	RESOLVED	p. 9
L-01	Peer Update Strands Verified Messages	Compatibility	LOW	RESOLVED	p. 10
L-02	Bridge fee event can overstate paid fee	Events	LOW	RESOLVED	p. 11
L-03	L2 Post-Batch Validation Omits Endpoint Checks	Validation	LOW	RESOLVED	p. 12
I-01	No Receive-Side Validation Of Recipient	Validation	INFORMATIONAL	RESOLVED	p. 13
I-02	Skip/Burn Bypass bridgedSupply Accounting	Trust Assumptions	INFORMATIONAL	RESOLVED	p. 14
I-03	No Token Rescue On Gateway	Best Practices	INFORMATIONAL	RESOLVED	p. 15
I-04	Dual-Bridge Window During Migration	Trust Assumptions	INFORMATIONAL	ACKNOWLEDGED	p. 16
I-05	sendOhm Does Not Validate Recipient Address	Gas Optimization	INFORMATIONAL	RESOLVED	p. 17
I-06	Consider Additional DVN For Added Resilience	Suggestion	INFORMATIONAL	RESOLVED	p. 18
I-07	Unused V1 Chain ID Constants In LZConfigLib	Superfluous Code	INFORMATIONAL	ACKNOWLEDGED	p. 19
I-08	Old Bridge Deactivated Without Disabled Check	Trust Assumptions	INFORMATIONAL	RESOLVED	p. 20
I-09	Unresolved TODO Comments	Best Practices	INFORMATIONAL	ACKNOWLEDGED	p. 21

Findings continued.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
I-10	Enabled/Disable Events Omit Data Parameters	Events	INFORMATIONAL	ACKNOWLEDGED	p. 22
I-11	Non-Canonical Chains Have No Minting Cap	Trust Assumptions	INFORMATIONAL	RESOLVED	p. 23
I-12	Periphery Can Use Stale Gateway	Informational	INFORMATIONAL	RESOLVED	p. 24

REMEDIATION REVIEW

I-13	Stale _subActionTargetKind Storage	Best Practices	INFORMATIONAL	RESOLVED	p. 25
I-14	Queued Actions Remain After Policy Disable	Documentation	INFORMATIONAL	RESOLVED	p. 26
I-15	Cross-Batch Execution Order Is Not Enforced	Documentation	INFORMATIONAL	RESOLVED	p. 27
I-16	Delegate Clear Docs Mismatch	Documentation	INFORMATIONAL	RESOLVED	p. 28

MEDIUM **M-01**

RESOLVED

Optional DVNs inherit LayerZero defaults

CATEGORY Logical Error
LOCATION LZConfigLib.sol
REVIEW Main Review

DESCRIPTION

The bridge intends to pin LayerZero verification to exactly two required DVNs per route, but `LZConfigLib.encodeUlnConfig()` leaves optional DVNs in LayerZero's default-inherited state.

The helper encodes `optionalDVNCount = 0` with an empty `optionalDVNs` array. In LayerZero V2 OApp ULN config, 0 does not mean "zero optional DVNs"; it means "use the default config." To explicitly configure no optional DVNs, the value must be `type(uint8).max`.

This conflicts with the proposal's stated goal of eliminating LayerZero default drag-along and using dual-DVN verification: LayerZero Labs + Google Cloud for non-Berachain routes, and LayerZero Labs + Nethermind for Berachain routes. If current defaults have no optional DVNs, the resolved config may look correct today, but the raw app config still inherits defaults.

If LayerZero later adds default optional DVNs or changes the optional DVN threshold for a route, Olympus can inherit that change without governance action. Messages may then require an extra default DVN, increasing fees or blocking delivery if that DVN is unavailable or unsupported. In the bridge flow, users can burn OHM on the source chain while the destination mint remains stuck until the inherited requirement is satisfied or admins recover the message.

RECOMMENDATION

Use LayerZero's NIL sentinel for no optional DVNs: set `optionalDVNCount = type(uint8).max`, `optionalDVNThreshold = 0`, and keep `optionalDVNs` empty.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/281>

LOW **L-01**

RESOLVED

Peer Update Strands Verified Messages

CATEGORY	Compatibility
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/policies/bridge/LZBridgeGateway.sol#L319
REVIEW	Main Review

— DESCRIPTION

Calling `setPeer` can update or clear the peer for an EID. If messages from that peer are already verified on the LZ endpoint but not yet executed, they become permanently undeliverable, and `lzReceive` reverts on the peer check. Admin must proceed to manually recover each stranded message (i.e., skip, clear).

— RECOMMENDATION

Document this behavior. Consider a two-step peer removal (disable receives → wait for in-flight messages to settle → remove peer) or check for pending messages before clearing.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/283>

LOW **L-02**

RESOLVED

Bridge fee event can overstate paid fee

CATEGORY	Events
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/periphery/bridge/LZCrossChainBridge.sol#L68
REVIEW	Main Review

— DESCRIPTION

LZCrossChainBridge.sendOhm() emits msg.value as the fees field in Bridged, but msg.value is the native value supplied upfront, not necessarily the actual LayerZero fee paid.

LayerZero V2 refunds excess native value to the configured refund address. In this bridge flow, the gateway passes the user as the refund address, so any overpayment is returned, but the event still records the full original msg.value.

The actual fee charged by LayerZero is returned in MessagingReceipt.fee, which the gateway receives from EndpointV2.send(). However, that value is not surfaced in the Bridged event.

This could also lead to misaccounting in off-chain accounting systems that rely on the emitted fees value.

— RECOMMENDATION

Emit MessagingReceipt.fee.nativeFee as the paid fee, or rename/document the field as native value supplied.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/270>

LOW **L-03**

RESOLVED

L2 Post-Batch Validation Omits Endpoint Checks

CATEGORY	Validation
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/scripts/ops/batches/LZBridgeGatewayL2Batch.sol#L311
REVIEW	Main Review

— DESCRIPTION

`LZBridgeGatewayL2Batch._validateConfigureAndEnable` verifies the gateway is enabled, peers are set, and enforced options exist. However, unlike the Ethereum proposal, it does not verify that the LZ libraries are pinned (SendUln302/ReceiveUln302), ULN config (DVN addresses, confirmations), or executor config. The Ethereum proposal's `_validate` reads these values and endpoint state directly. A misconfigured L2 endpoint setup would therefore not be caught by the L2 post-batch validation.

— RECOMMENDATION

Extend `_validateConfigureAndEnable` to read endpoint configuration via the gateway's `ILZEndpointV2Admin` view functions and verify libraries, DVNs, confirmations, and executor match the expected values. Mirror the checks in `LZBridgeSecurityUpgradeProposal._validateLZConfig`.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/269>

INFORMATIONAL I-01

RESOLVED

No Receive-Side Validation Of Recipient

CATEGORY Validation

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/policies/bridge/LZBridgeGateway.sol#L301>

REVIEW Main Review

DESCRIPTION

`_receiveBridge0hm` decodes `(address to, uint256 amount)` from the cross-chain message but does not validate `to`. The send side checks `to != address(0)`, but the receive side trusts the payload entirely. If a situation occurs where `to = address(0)` is sent to the receiver, the OHM mint reverts, stranding the message. If `to = address(gateway)`, OHM is minted to the gateway and locked with no recovery path.

RECOMMENDATION

Add `_requireNonzeroAddress(to, "to")` in `_receiveBridge0hm`, consider also rejecting `to == address(this)`.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/267>

INFORMATIONAL I-02

RESOLVED

Skip/Burn Bypass bridgedSupply Accounting

CATEGORY Trust Assumptions

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/policies/bridge/LZBridgeGateway.sol#L465>

REVIEW Main Review

DESCRIPTION

The LZ V2 message recovery functions `skip`, `burn`, and `clear` are executed directly to the endpoint without adjusting `bridgedSupply` or mint approval on the canonical chain. When `bridge_admin` uses `skip` or `burn` to permanently discard an inbound message, the OHM burned on the source chain is never minted on the destination, but `bridgedSupply` remains inflated. Admin must manually call `decreaseBridgedSupply` to enforce the `bridgedSupply` and mint approval are up-to-date, while nothing in the code enforces or signals this.

RECOMMENDATION

Document that `skip` and `burn` of messages require a corresponding `decreaseBridgedSupply` call on the canonical chain.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/266>

INFORMATIONAL **I-03**

RESOLVED

No Token Rescue On Gateway

CATEGORY	Best Practices
LOCATION	LZBridgeGateway.sol, LZCrossChainBridge.sol
REVIEW	Main Review

DESCRIPTION

Neither `LZBridgeGateway` nor `LZCrossChainBridge` has a mechanism to recover tokens accidentally sent to them. ERC20 and native token is permanently locked, and since the gateway's `lzReceive` is payable, this can increase the chance user stuck funds.

RECOMMENDATION

Consider adding an admin-gated rescue function for stuck tokens.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/264>

INFORMATIONAL **I-04**

ACKNOWLEDGED

Dual-Bridge Window During Migration

CATEGORY	Trust Assumptions
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/proposals/LZBridgeSecurityUpgradeProposal.sol#L73
REVIEW	Main Review

DESCRIPTION

The OCG proposal enables the new `LZBridgeGateway` but does not deactivate the old `CrossChainBridge`. Deactivation is deferred to a separate DAO multisig batch after proposal execution. During this window both bridges are active. The old bridge lacks `bridgedSupply` tracking, DVN pinning, and receive-side disable checks. Transfers through the old bridge during this window bypass `bridgedSupply` tracking, explicit DVN pinning, and receive-side disable controls.

RECOMMENDATION

Minimize the window between proposal execution and old bridge deactivation. Document the maximum acceptable delay and ensure monitoring is in place to alert if the old bridge is used after the new one is live.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-05**

RESOLVED

sendOhm Does Not Validate Recipient Address

CATEGORY Gas Optimization

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/policies/bridge/LZBridgeGateway.sol#L209>

REVIEW Main Review

DESCRIPTION

`LZCrossChainBridge.sendOhm` validates `amount_ != 0` but does not check `to_ != address(0)`. The gateway's `burnAndSend` does validate this, but the user has already paid gas for the OHM transfer before hitting that revert.

RECOMMENDATION

Add `_requireNonzeroAddress(to_, "to")` in `sendOhm` to fail fast.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/265>

INFORMATIONAL **I-06**

RESOLVED

Consider Additional DVN For Added Resilience

CATEGORY	Suggestion
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/libraries/LZConfigLib.sol#L271-L272
REVIEW	Main Review

— DESCRIPTION

The bridge uses 2-of-2 required DVNs per route, which meets LayerZero's multi-DVN recommendation and would have added an extra layer of protection against the recent KelpDAO exploit (April 2026) which relied on a 1-of-1 configuration. However, a 2-of-2 setup means compromising both DVNs still enables message forgery. A 3-of-3 configuration would provide additional resilience against attackers targeting DVN infrastructure, as demonstrated in the KelpDAO incident.

— RECOMMENDATION

Evaluate whether adding a third required DVN is operationally feasible to add an extra layer of security.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/281>

INFORMATIONAL **I-07**

ACKNOWLEDGED

Unused V1 Chain ID Constants In LZConfigLib

CATEGORY	Superfluous Code
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/libraries/LZConfigLib.sol#L117-L125
REVIEW	Main Review

DESCRIPTION

`LZConfigLib` defines V1 LayerZero chain ID constants (`ETH_CHAIN_ID = 101` , `ARB_CHAIN_ID = 110` , etc.) that are not referenced anywhere in the codebase. All active configuration uses the V2 endpoint IDs (`ETH_EID = 30101` , `ARB_EID = 30110` , etc.).

RECOMMENDATION

Remove the unused V1 chain ID constants to reduce confusion between V1 and V2 identifiers.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-08**

RESOLVED

Old Bridge Deactivated Without Disabled Check

CATEGORY Trust Assumptions

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/scripts/ops/batches/LZCrossChainBridgeBatch.sol#L33-L59>

REVIEW Main Review

DESCRIPTION

`LZCrossChainBridgeBatch.setup` deactivates the old `CrossChainBridge` in the Kernel without first verifying that `bridgeActive == false`. A separate `disableOldBridge` entry point exists and is expected to run beforehand, but `setup` does not enforce this ordering. If `setup` is ran before `disableOldBridge`, user transactions submitted in the intervening window could still interact with the old bridge.

RECOMMENDATION

Add a pre-condition check in `setup` that verifies the old bridge's `bridgeActive` state is already false, or include the `disable` call in the same batch to guarantee ordering.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/272>

INFORMATIONAL I-09

ACKNOWLEDGED

Unresolved TODO Comments

CATEGORY	Best Practices
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/scripts/deploy/DeployV3.s.sol#L67 , https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/scripts/ops/batches/LZBridgeGatewayBatch.sol#L90 , https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/proposals/LZBridgeSecurityUpgradeProposal.sol#L64 , https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/proposals/LZBridgeSecurityUpgradeProposal.sol#L95-L98
REVIEW	Main Review

— DESCRIPTION

Several TODO comments remain in the proposal, deployment scripts, and batch scripts that should be resolved before deployment:

`LZBridgeSecurityUpgradeProposal.sol` : proposal ID is hardcoded to 15 with a TODO. The proposal description contains TODO placeholders for the audit report link, PR link, and RFC/OIP reference.

`LZBridgeGatewayBatch.sol` : `initBridgedSupply` reads from an args file with a TODO noting the value must be set before execution.

`DeployV3.s.sol` : TODOs flag refactoring and error handling improvements.

— RECOMMENDATION

Resolve all TODO comments before deployment, followed by removing the comments to avoid confusion.

— RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-10**

ACKNOWLEDGED

Enabled/Disable Events Omit Data Parameters

CATEGORY	Events
LOCATION	LZBridgeGateway.sol, PolicyEnabler.sol
REVIEW	Main Review

DESCRIPTION

`PolicyEnabler.enable` and `PolicyEnabler.disable` each accept a bytes calldata data parameter (`enableData_` and `disableData_`) but do not include these in the Enabled and Disabled events. For policies that use this data for configuration at enable/disable time, the values are not captured in on-chain logs.

RECOMMENDATION

Consider emitting `enableData_` and `disableData_` as part of the Enabled and Disabled events.

RESOLUTION

Status: Acknowledged.

<https://github.com/OlympusDAO/olympus-v3/pull/258>

INFORMATIONAL I-11

RESOLVED

Non-Canonical Chains Have No Minting Cap

CATEGORY Trust Assumptions

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/aaae73e623307712c952179a38cfb66637c0ae21/src/policies/bridge/LZBridgeGateway.sol#L602>

REVIEW Main Review

DESCRIPTION

In non-canonical chains, `_receiveBridge0hm` uses JIT self-approval with no upper bound:

```
MINTR.increaseMintApproval(address(this), amount);
```

```
MINTR.mint0hm(to, amount);
```

If for example LayerZero verification infrastructure for a specific route is compromised (e.g. DVN compromised as demonstrated by the KelpDAO incident in April 2026), unlimited `0HM` can be minted on the non-canonical chain. The canonical chain's `bridgedSupply` cap does not protect non-canonical chains.

The `RateLimiter` inherited by the gateway caps outbound transfers only. `_inflow` reduces consumed outbound capacity, freeing it for further sends, rather than capping inbound volume. Rate limits therefore do not provide an effective cap on inbound mints if LZ verification is compromised.

RECOMMENDATION

Consider whether a `maximum-mint cap` should be introduced at the gateway level on non-canonical chains as an additional defense layer.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/282>

INFORMATIONAL **I-12**

RESOLVED

Periphery Can Use Stale Gateway

CATEGORY	Informational
LOCATION	DeployV3.s.sol
REVIEW	Main Review

— DESCRIPTION

The saved LZ bridge deployment sequences deploy LZCrossChainBridge before LZBridgeGateway.

DeployV3.deploy() executes the sequence in order and stores each deployed address in the in-memory deployedTo map only after that deployment completes. DeployV3._getAddressNotZero() first checks this in-memory map, then falls back to env.json.

However, deployLZCrossChainBridge() reads olympus.policies.LZBridgeGateway during construction. Since LZBridgeGateway appears later in both saved LZ deployment sequences, the newly deployed gateway is not available in deployedTo when the periphery is constructed.

As a result, the periphery either reverts if env.json has no gateway address, or it is deployed with whatever gateway address was already saved in env.json. If env.json contains an older gateway address, the new periphery is wired to that stale gateway instead of the gateway deployed later in the same sequence.

— RECOMMENDATION

Deploy LZBridgeGateway before LZCrossChainBridge, or explicitly require that env.json already contains the intended gateway address before deploying the periphery.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/271>

INFORMATIONAL I-13

RESOLVED

Stale `_subActionTargetKind` Storage

CATEGORY Best Practices

LOCATION <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/lz-bridge-upgrade/src/policies/bridge/LZBridgeAndDelegateConfig.sol#L297>, <https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/lz-bridge-upgrade/src/policies/bridge/LZBridgeAndDelegateConfig.sol#L93C63-L93C83>

REVIEW Remediation Review

DESCRIPTION

When a queued action is executed or cancelled, `_queuedActions[actionId].actions` is deleted, but the per queued sub-action `_subActionTargetKind[actionId][index]` mapping entries are not. These entries remain in storage permanently after the action completes, even though they are never read again.

RECOMMENDATION

Clear `_subActionTargetKind[actionId][index]` entries in the execution and cancellation paths.

RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/296/changes/17ea083bef398c78d2594f2a1799ec3f79566506>

INFORMATIONAL **I-14**

RESOLVED

Queued Actions Remain After Policy Disable

CATEGORY	Documentation
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/lz-bridge-upgrade/src/policies/bridge/LZBridgeAndDelegateConfig.sol#L287
REVIEW	Remediation Review

— DESCRIPTION

When `LZBridgeAndDelegateConfig` is disabled for security purposes, `_validateExecution` blocks execution of queued actions via `_requireEnabled()`, but the queued actions remain in storage.

If the policy is disabled and later re-enabled, any previously-queued actions (whose execution windows have not expired yet) become executable again. An operator who re-enables the policy without first cancelling all potentially dangerous queued actions could allow a malicious action to complete.

— RECOMMENDATION

Document the operational procedure that all malicious queued actions must be cancelled by the emergency role before the policy is re-enabled.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/296/changes/598f9654c534cb97e3a30ba699d136e35fdf79ec>

INFORMATIONAL **I-15**

RESOLVED

Cross-Batch Execution Order Is Not Enforced

CATEGORY	Documentation
LOCATION	https://github.com/GuardianOrg/olympus-v3-team1-1776174364780/blob/lz-bridge-upgrade/src/policies/utils/TimeLockBatchQueue.sol#L126
REVIEW	Remediation Review

— DESCRIPTION

Within a queued batch, sub-actions execute atomically in array order. Across separate queued actions, there is no enforced ordering, and execution is permissionless, so two independently-queued batches can be executed in any order once their timelocks elapse. Operators who queue dependent actions in separate batches cannot rely on them executing in queue order.

— RECOMMENDATION

Document that actions with execution-order dependencies must be queued within a single batch, and that independent batches should not be assumed to execute in queue order.

— RESOLUTION

Status: Resolved.

<https://github.com/OlympusDAO/olympus-v3/pull/296/changes/76a37ad8cd536580a0b3b38ce36cd0569d01c421>

INFORMATIONAL **I-16**

RESOLVED

Delegate Clear Docs Mismatch

CATEGORY	Documentation
LOCATION	ILZBridgeGateway.sol
REVIEW	Remediation Review

— DESCRIPTION

The ILZBridgeGateway.setDelegate() interface documents that passing address(0) clears the LayerZero endpoint delegate.

However, LZBridgeGateway.setDelegate() calls validateSetDelegate(delegate_), and validateSetDelegate() rejects the zero address. The timelocked LZBridgeAndDelegateConfig path also calls the same validation helper before queueing setDelegate, so zero-address delegate clearing is not available through either direct or timelocked configuration.

As a result, operators or scripts following the interface documentation may attempt to clear the delegate with address(0) and see the action revert at validation or execution time. The implementation still supports replacing the delegate with another nonzero address, so this is a documentation/API consistency issue rather than a loss of delegate control.

— RECOMMENDATION

Update the interface documentation to state that delegate_ must be nonzero.

— RESOLUTION

Status: Resolved.

<https://github.com/0lympusDAO/olympus-v3/pull/296/changes/55603b2000e5bf7dfe50caab456e301b517f57af>

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.